



PIXOUS TECHNOLOGIES

Role-Wise Unit Testing Specification

HR Management Portal — Client Submission

Version 1.0 · 2026-08-14

Pixous HR Portal — Role-Wise Unit Testing Specification

Field	Value
Version	1.0
Date	2026-08-14
Framework (backend)	JUnit 5 + Mockito — <code>cd backend && mvn test</code>
Framework (frontend)	Vitest + React Testing Library — <code>cd web && npm test</code>
Roles covered	SUPER_ADMIN, COMPANY_ADMIN, HR_MANAGER, TEAM_LEAD, EMPLOYEE
Executed tests today	62 automated (40 backend + 22 frontend) — all green

1. Purpose

Every test in this suite exists to protect a **role's ability to do its job** — and to stop a user from doing a job they were **not** given. Tests are therefore organised by role: each role owns a set of capabilities, and each capability owns a set of test cases. A regression in any role's flow is caught the same moment it is introduced.

1.1 The Role → Test Ownership Map

Role	Core capability tested	Test classes
All roles	Authentication, sessions, tokens, validation	<code>JwtServiceTest</code> , <code>AuthDtosValidationTest</code> , <code>LoginAttemptLimiterTest</code> , <code>AuthServiceTest</code> , <code>Login.test.tsx</code>
SUPER_ADMIN	Platform control, tenancy, data reset, module mgmt	Role-matrix tests RT-01...RT-08 (planned)
COMPANY_ADMIN	Tenant admin, roles & permissions, audit	Role-matrix tests RT-09...RT-14 (planned)
HR_MANAGER	Employee lifecycle, leave, payroll, reports	B-19...B-40 + RT-15...RT-22 (planned)
TEAM_LEAD	Team approvals, tasks, presence	RT-23...RT-28 (planned)
EMPLOYEE	Self-service: profile, attendance, claims, payslips	Frontend F-01...F-22 + RT-29...RT-34 (planned)

2. How to Run

```
# Backend – all 40 tests
cd backend
mvn test

# Frontend – all 22 tests
cd web
npm test
```

Definition of Done for a role feature: its role-matrix tests (RT-xx) exist, run green, and cover the positive path, at least one negative path, and at least one authorisation boundary.

3. Executed Test Inventory (62) — grouped by role

3.1 Shared security core — protects ALL roles (backend B-01...B-16)

ID	Test	What it protects
B-01	<code>generatesTokenThatParsesBackToSameIdentity</code>	JWT issue/verify round-trip
B-02	<code>tokenExpiresAtConfiguredTtl</code>	Token lifetime
B-03	<code>rejectsTamperedPayload</code>	Token tampering
B-04	<code>rejectsTokenSignedWithDifferentSecret</code>	Cross-signature forgery
B-05	<code>rejectsGarbageAndEmptyTokens</code>	Malformed input
B-06	<code>missingRolesClaimYieldsEmptyList</code>	Missing-claim safety
B-07	<code>allowsAttemptsUpToThreshold</code>	Rate-limiter: happy path
B-08	<code>blocksAfterEightFailures</code>	Brute-force lockout
B-09	<code>blocksEitherIdentityIndependently</code>	Per-identity isolation
B-10	<code>successfulLoginClearsTheStreak</code>	Lockout reset
B-11	<code>countingIsCaseInsensitiveOnUsername</code>	Case handling
B-12	<code>differentUsersAreNotBlockedByEachOther</code>	No cross-user lockout
B-13	<code>loginRequiresBothFields</code>	Login DTO validation
B-14	<code>loginAcceptsValidCredentials</code>	Login happy path
B-15	<code>changePasswordRequiresNewPasswordAtLeastEightChars</code>	Password policy
B-16	<code>signupRejectsShortUsernameAndPassword</code>	Signup policy

3.2 Authentication flows — ALL roles (backend B-17...B-29)

ID	Test	Role benefit
B-17	<code>loginSuccessIssuesTokensAndClearsFailures</code>	Everyone signs in
B-18	<code>loginWithUnknownUserThrowsBadCredentialsAndRecordsFailure</code>	No user enumeration
B-19	<code>loginByFullNameWorksWhenSingleMatch</code>	Username flexibility
B-20	<code>fiveWrongPasswordsLockTheAccount</code>	Account protection

B-21	<code>disabledAccountRejectedEvenWithCorrectPassword</code>	Deactivated users blocked
B-22	<code>legacyUserWithoutCompanyIsAutoAssignedToPixous</code>	Tenant auto-assignment
B-23	<code>refreshRotatesTheTokenAndRevokesTheOldOne</code>	Refresh rotation
B-24	<code>refreshWithRevokedTokenIsRejected</code>	Replay protection
B-25	<code>refreshWithExpiredTokenIsRejected</code>	Expiry enforcement
B-26	<code>changePasswordRejectsWrongCurrentPassword</code>	Credential change safety
B-27	<code>changePasswordSuccessRevokesAllSessions</code>	Logout-everywhere
B-28	<code>signupRejectsDuplicateUsername</code>	Duplicate prevention
B-29	<code>signupAssignsDefaultRoleAndEncodesPassword</code>	Safe default role

3.3 Signup validation — onboarding (backend B-30...B-33)

ID	Test	Input guards
B-30	<code>signupRejectsMalformedAadhaar</code>	Aadhaar format
B-31	<code>signupRejectsMalformedPhone</code>	Phone format
B-32	<code>signupAcceptsValidPayload</code>	Happy path
B-33	<code>keepsAllowlistedExtension</code>	Storage allowlist

3.4 File storage — ALL roles (backend B-34...B-40)

ID	Test	What it protects
B-34	<code>htmlUploadIsStoredAsBin</code>	HTML/script neutralisation
B-35	<code>svgUploadIsStoredAsBin</code>	SVG XSS neutralisation
B-36	<code>doubleExtensionTakesLastPart</code>	Double-extension spoof
B-37	<code>uppercaseExtensionIsNormalized</code>	Case spoof
B-38	<code>noExtensionBecomesBin</code>	Extension-less files
B-39	<code>emptyFileIsRejected</code>	Empty uploads
B-40	<code>uploadedFilenameIsNeverUsedInPath</code>	Path traversal

3.5 Frontend — EMPLOYEE & shared UI (F-01...F-22)

ID	Test	Area
F-01...F-06	<code>utils.test.ts</code> — class merge, falsy filter, initials, month names, INR format, durations	Shared UI helpers
F-07...F-12	<code>dates.test.ts</code> — 12h/24h, padding, dash fallback, unparseable, today, this-month	Date helpers
F-13...F-22	<code>Login.test.tsx</code> — renders form, validation errors, submit → API, loading state, error display, disabled state	Login page (all roles)

4. Role-Wise Test Specification (planned — RT-01...RT-34)

Each role section lists the **mandatory unit tests** for that role's capabilities, mapped to functional requirements (FR-xx). "Authz negative" means: an actor with a **lesser** role must get 403 while a **greater** role succeeds.

4.1 SUPER_ADMIN (System Admin) — RT-01...RT-08

ID	Test case	FR	Expectation
RT-01	Creating a company creates an isolated tenant row	FR-18	company row + tenant isolation by <code>company_id</code>
RT-02	Company admin cannot create companies (authz negative)	FR-18	403
RT-03	Data reset requires explicit confirmation token	FR-19	aborts without confirmation
RT-04	Data reset never executes in prod profile	FR-19	seeder/guard blocked
RT-05	Enabling/disabling a module persists and is respected	FR-26	module toggle applies
RT-06	Clearing cache endpoints require SUPER_ADMIN	FR-26	403 for others
RT-07	Audit log records privileged actions with actor + timestamp	FR-15	entries written
RT-08	SUPER_ADMIN token parses with full authority list	FR-01	authorities include all <code>*_MANAGE</code>

4.2 COMPANY_ADMIN — RT-09...RT-14

ID	Test case	FR	Expectation
RT-09	Assigning a role persists and appears in the JWT	FR-16	role change reflected
RT-10	HR cannot assign roles (authz negative)	FR-16	403
RT-11	Tenant settings update is scoped to own company	FR-17	other tenants unaffected
RT-12	Company admin audit query returns own-tenant entries only	FR-15	no cross-tenant leak
RT-13	Company admin can view all employees of own tenant	FR-03	full employee list
RT-14	Employee cannot access company settings (authz negative)	FR-17	403

4.3 HR_MANAGER — RT-15...RT-22

ID	Test case	FR	Expectation
RT-15	Creating an employee assigns default role EMPLOYEE	FR-03	role + encoded password
RT-16	Deactivating an employee blocks their login	FR-03	login 403 even with correct password
RT-17	Approving leave updates balance and status	FR-04	balance decremented once
RT-18	TL cannot approve another team's leave (authz negative)	FR-04	403
RT-19	Payroll run computes payslips for active employees	FR-06	payslip rows created
RT-20	Duplicate payroll run for same period is rejected	FR-06	no double-pay
RT-21	Report export respects pagination and filters	FR-14	filtered, paged rows
RT-22	Performance review creation validates ratings	FR-23	invalid rating rejected

4.4 TEAM_LEAD — RT-23...RT-28

ID	Test case	FR	Expectation
----	-----------	----	-------------

RT-23	TL sees only own team's attendance/leave queue	FR-04/05	team-scoped rows
RT-24	TL can approve team leave within delegation limits	FR-04	approval recorded
RT-25	TL assigning a task adds the assignee + chat thread	FR-24	task + thread created
RT-26	Employee cannot assign tasks (authz negative)	FR-24	403
RT-27	TL review of work reports is team-scoped	FR-25	only own team
RT-28	Presence API returns team members' status	FR-22	status list

4.5 EMPLOYEE — RT-29...RT-34

ID	Test case	FR	Expectation
RT-29	Clock-in/out creates attendance row once per day	FR-05	one row, correct state
RT-30	Employee cannot clock in for another user (authz negative)	FR-05	403
RT-31	Leave application is rejected when balance is insufficient	FR-04	business error
RT-32	Claim submission validates amount and receipt	FR-08	invalid rejected
RT-33	Payslip endpoint returns only own payslips	FR-06	own rows only
RT-34	Self profile update cannot change own role	FR-03	role immutable

5. Authorisation Boundary Matrix (must be tested for every endpoint)

Actor → tries to access	SA data	CA data	HR data	TL data	Own data
SUPER_ADMIN	✓	✓	✓	✓	✓
COMPANY_ADMIN	✗ 403	✓	✓	✓	✓
HR_MANAGER	✗ 403	✗ 403	✓	✓	✓
TEAM_LEAD	✗ 403	✗ 403	✗ 403	✓ (own team)	✓
EMPLOYEE	✗ 403	✗ 403	✗ 403	✗ 403	✓
Anonymous	✗ 401	✗ 401	✗ 401	✗ 401	✗ 401

This matrix is the acceptance gate: **any endpoint whose matrix cell is ✗ must return

401 / 403 — verified by a unit test before the feature ships.**

6. Coverage Targets by Role

Role	Current	Target (next 2 sprints)
Shared security core (all roles)	62% of planned	100%
SUPER_ADMIN	0% (RT-01...08 not yet written)	100%
COMPANY_ADMIN	0% (RT-09...14)	100%
HR_MANAGER	~40% (B-19...B-29 cover auth flows)	100%
TEAM_LEAD	0% (RT-23...28)	100%

EMPLOYEE	~35% (F-01...F-22 cover UI self-service)	100%
----------	--	------

Command to measure backend coverage (JaCoCo):

```
cd backend && mvn test jacoco:report
# report: backend/target/site/jacoco/index.html
```

This document is version-controlled in the repository ([docs/ROLE-WISE-TESTING.md](#)). Any role, permission, or endpoint change must update the boundary matrix above and its RT-xx tests.